Second Sig: demo and pitch

Oct 22, 2026 · @Rafi

One script serves the live demo and the video: three scenarios, two clicks each, three minutes.

The three-minute demo

Bybit goes first because it is the whole argument in a minute; Aave shows it isn't a brick wall; the auditor shows what only the model can do. Nothing is typed on stage, every beat is a click, and the verdict is said out loud only after the badge is on screen.

Time	On screen	Click	Say
0:00	Bybit tab, banner		"In February 2025, Bybit's signers approved what their screen showed them. The bytes they signed did something else, and about $1.4 billion left. Second Sig checks the bytes, and the vault itself refuses to run anything it hasn't checked."
0:20	Proposal strip	`Judge`	"This is a real Safe multisig on a fork of Ethereum. Two of three owners have already signed. The description says transfer 500 ETH. We ask the judge."
0:30	Cards 1 and 2 fill		"Left, what the signer was told. Middle, what the bytes actually do when we run them. No ETH moves; the vault's master code is replaced. That's the attackers' real contract, still on mainnet."
0:50	Card 3		"Our hard floor in code already rejected it. Gemini 4 Argon, reading the contract source, agrees and says why."
1:00	Result line	`Execute on the vault`	"Two valid signatures. The real Safe contract asks our guard, there's no stamp, and it reverts. The signers' screen could have said anything."

Time	On screen	Click	Say
1:15	Aave tab	tab, then `Judge`	"Now honest work. Depositing 10,000 USDC into Aave touches several contracts and dozens of storage values. A rule engine would panic."
1:30	Card 3 streaming		"Argon has the real Aave source in context, about four hundred thousand tokens, and is checking each change is a normal deposit." Let it stream for ten seconds.
1:45	MATCH	`Execute on the vault`	"Match. Stamp signed. Executes. The vault holds aUSDC, and no human was interrupted."
2:00	Auditor tab	tab, then `Judge`	"Last one. Pay our auditor 100 USDC. True. The bytes also let the auditor spend unlimited USDC, forever. No single rule catches this without false alarms, because unlimited approvals are sometimes intended."
2:20	ASK	`Execute on the vault`	"The judge asks one question instead of guessing. No stamp, so the chain refuses until a human answers."
2:35	Top bar		"Everything you saw is real code: a Safe deployed through Safe's own factory, real Aave, the real Bybit contract. The only thing we wrote on-chain is an eighty-line guard, installed with one transaction. Second Sig: the signature your signatures can't replace."
2:55			Questions.

If something stalls. A model call past twenty seconds: click `Replay from log`, say "replaying this morning's run", carry on. The fork misbehaves: `Reset`, re-run the scenario; if it fails twice, play that scenario's clip from the video and move on. Never narrate the failure for more than one sentence.

Video plan

One 3:00 screen recording of the page, with the script above as voice-over. It satisfies the Gemini brief (three minutes) and Agents That Ship (two to four), and it is the fallback for any live beat that fails.

Time	Shot
0:00 to 0:12	Plain text on the page's background: the Bybit date, the loss, and "Signers approved what their screen showed. The chain ran what they signed."
0:12 to 1:15	Bybit scenario, exactly as the script: Judge, cards fill, Execute, revert
1:15 to 2:00	Aave scenario, with ten seconds of the reasoning stream left in
2:00 to 2:35	Auditor scenario
2:35 to 3:00	Slow pan over the top bar and the guard's `attest` function in the editor, closing line, repo URL

How it gets made without eating Sunday.

- Record each scenario as its own clip the moment it works end to end, at 1440 by 900, 125% zoom, cursor visible. A clip recorded Saturday night is insurance.
- Voice-over recorded separately from the script, one take per row, then cut to the clips. Easier to fit three minutes than a live narration.
- Captions burned in for every command and verdict, so it reads with the sound off on a judge's laptop.
- Rafi writes the script Saturday evening and cuts; the chain lead records the on-chain beats at G2 and G3.
- Final export by Sunday noon, uploaded before the freeze. Hackathon wifi is slowest in the last hour.

Judges' questions

Every hard question has a short, honest answer, and most of them are "yes, that's a limit, and here is what bounds it". The name in brackets takes it on the day.

Question	Answer
Why not just hard rules? (Rafi)	Rules are in the system and they catch Bybit on their own. They only hold rules with no honest counterexample. The model's job is the rest: letting honest complexity through without interrupting a human, and asking about the true-but-incomplete case.
What about prompt injection in the description? (Rafi)	The backward pass never sees the description, so the words can't steer what the bytes are reported to do. Every model output is a typed form. The worst an injection achieves is pushing a transaction to ASK.
Can't Argon just say MATCH on a hijack? (Rafi)	Not for the floor's cases: a floor hit is REJECT whatever the model says. For subtler cases, yes, the model can be wrong, and the pitch says so; the floor is why that doesn't lose the vault's code or its owners.
What if the judge is offline, or its key is lost? (chain lead)	All owners can call `approveOverride` on the guard directly and the transaction executes without a stamp. It's deliberately a wider quorum than normal. A timelock on it is the first thing we'd add.
What if the judge key is stolen? (chain lead)	The stamp is necessary, not sufficient. A thief still needs the owners' signatures. Stealing the key removes one check; it doesn't move funds.
The fork can differ from mainnet. (chain lead)	True. The stamp binds the fork block and expires after 100 blocks; environment-sensitive contracts are future work.
Bybit's Safe didn't support guards. (chain lead)	Right, it was v1.1.1. We replay the attack shape against a v1.4.1 Safe with the guard set. Any Safe from 1.3.0 on can install this today with one `setGuard` transaction.
Isn't the judge a central point of trust? (both)	One judge today, and it can only add a requirement, never remove one. Several independent judges with k-of-n stamps is the obvious next step.

Question	Answer
How slow, how much does it cost? (Rafi)	Read the stage line's token count and the wall time from `logs/`. Never estimate on stage.
Why Gemini 4 Argon specifically? (Rafi)	The Aave beat: the whole verified source of every touched contract in one context, with reasoning deep enough to say which of forty storage writes is a normal deposit. Flash runs the two blind passes, where speed matters more than depth.

Pre-flight, ten minutes before

- [ ] `anvil` running at the pinned block; RPC cache warm, so pull the network and run Bybit once to prove it
- [ ] `uvicorn` running; page open at 125% zoom; `Reset` clicked
- [ ] All three scenarios run once in the last ten minutes; logs fresh for `Replay from log`
- [ ] Backup video open in a second tab, paused at 0:00
- [ ] Laptop plugged in, notifications off, display mirroring on, screen never sleeps
- [ ] Second laptop with the repo and the video, in case the first one dies
- [ ] Whoever isn't clicking holds the Q&A sheet

Friday

Tonight is accounts and installs. Whether a spec and a `CLAUDE.md` count as pre-written work is the first thing to check at the venue, because Encode's public pages don't say.

Accounts and keys (tonight).

- [ ] Gemini API key on the hackathon credits; one test call each to `gemini-4-argon` and `gemini-3.8-flash` in AI Studio
- [ ] Mainnet RPC that serves state at the pinned block (Alchemy or similar; anvil does the tracing locally, so the provider needs no debug namespace)
- [ ] Etherscan API key, for verified source and ABIs
- [ ] A fresh judge key and three owner keys, generated with `cast wallet new`, kept in `.env`, never committed

Installs (tonight).

- [ ] Foundry (`forge`, `anvil`, `cast`), current release, on both laptops

- [ ] Python 3.12 with `uv`; `google-genai`, `web3`, `eth-account`, `pydantic`, `fastapi`, `sse-starlette`
- [ ] Node 20 with `pnpm`; Vite, React, Tailwind
- [ ] `safe-smart-account` cloned at the v1.4.1 tag, for `BaseGuard` and the tests

Rule checks (venue, first hour).

- [ ] Is pre-written code allowed? If not, the repo starts empty at kickoff and these docs are planning
- [ ] Can one project enter both the Gemini challenge and Agents That Ship?
- [ ] Submission time, where the video goes, and whether judging is live at a table, on stage, or from the video

Workshop questions (Gemini session, Friday afternoon).

- [ ] Thought summaries on `gemini-4-argon` with streaming: which flag, and does it work with `response_schema`?
- [ ] Rate limits on the hackathon credits for a 400k-token call with `thinking_level: high`
- [ ] Whether function calling and `response_schema` combine in one call (we don't need it, but it settles an old note)

Technical checks (Friday night, before anyone sleeps).

- [ ] Our anvil build returns `prestateTracer` in diff mode; if not, the struct-log SSTORE fallback
- [ ] `getTransactionHash` parameter order on the v1.4.1 tag, and that `setGuard` accepts our guard's ERC-165 answer
- [ ] The USDC holder we impersonate still holds enough at the pinned block
- [ ] The Bybit attackers' contract has code at the pinned block (`cast code 0x9622...7242`)